

VAMP findings into Application Vulnerability Response

Architecture diagram: Kafka consumer, import set and transform map, out-of-box AVR import API

Prepared 25 September 2026. Architecture only; build plan and field mapping follow once the VAMP payload is available. The table says which out-of-box code the design uses and which it cannot; the figure on the next page shows the whole path, in the shape of the CDP IVR inbound build with the application-vulnerability API in place of the infrastructure one.

Out-of-box code: what is used, what is not, and why

Component	Out of the box	In this story
Stream Connect on Hermes	Hermes, ServiceNow's own Kafka cluster (hermes-internal); Kafka topic, subscription, topic alias, stream, script consumer (sys_kafka_* and sys_sc_topic_alias)	Configured. VAMP publishes to the Hermes topic sn_user_vamp_inbound (exists on dev); alias, stream and consumer live in the application scope. No external cluster.
Import sets	sys_import_set, staging table, GlideImportSetTransformer, transform map engine with onStart / onBefore / onComplete	Used as the front door, exactly as in the CDP IVR build: one import set per message, one row per finding, transformAllMaps().
AVR import API	sn_vul.AVRImportAPIFactory, AVRImportAPI_v1Base, AVRImportAPIBase: createOrUpdateApp, createOrUpdateAppVulEntry (+ CWE links), createOrUpdateAVIT	Called from the transform map scripts. Required fields: app_name + source_app_id (application); source_entry_id + source_severity (entry); source_app_id, source_scan_id, source_avit_id, source_severity, source_entry_id, scan_type (AVIT).
Application matching	sn_vul.AppVulUtils.productModelOrScannedApp with the CI lookup rules (sn_sec_cmh.CIIdentify)	Inherited through the API: business application when a rule matches, otherwise a Scanned Application record.
State mapping	sn_vul_app_state_map rows per integration, read by sn_vul.VulnerabilityStateManager	Configured: one row per VAMP status, giving state and substate. No status logic in script.
Integration framework records	sn_sec_int_integration, sn_sec_int_impl, sn_vul_int_fw_integration_run and _process (or classic sn_vul_integration_run / _process; the API accepts both)	Integration and instance created once; run and process written per message by onStart, counts by onComplete, so the import is auditable like a scheduled one.
sn_vul.Detection, sn_vul.ImportHost	The infrastructure (IVR) detection API used by the CDP IVR build	Not used: they create host-based vulnerable items (sn_vul_vulnerable_item), not application findings.
Kafka transform map consumer	sys_kafka_transform_map_consumer: JSON keys mapped to import set columns without code	Not used: it takes one message as one row, and a VAMP message can carry several findings. The scripted consumer keeps the same front door.
ManualIngestionAVRPentestProcessor	The only OOB code that creates sn_vul_pen_test_assessment_request	Not usable: insert-only, bound to spreadsheet ingestion, application looked up by name. The AVR import API has no method for the table.
Pen test assessment request	None	Built: onBefore finds the request by u_assessment_id (VAMP assessment id) or inserts it with the fields the OOB processor sets, and passes it as assessment_request to createOrUpdateAVIT.
Flow Designer	Flows and actions	Not used, as the story asks.

VAMP findings reach Application Vulnerability Response over Kafka

VAMP has no integration into ServiceNow today. The consumer stages one row per finding; the Transform Map's own scripts hand each row to the **AVR import API**, the code every application-scanner integration already uses, so application matching, vulnerability entries, state mapping and the AVIT lifecycle are inherited. One table the API does not cover, the pen test request, is filled by a small lookup-or-create in the same script.

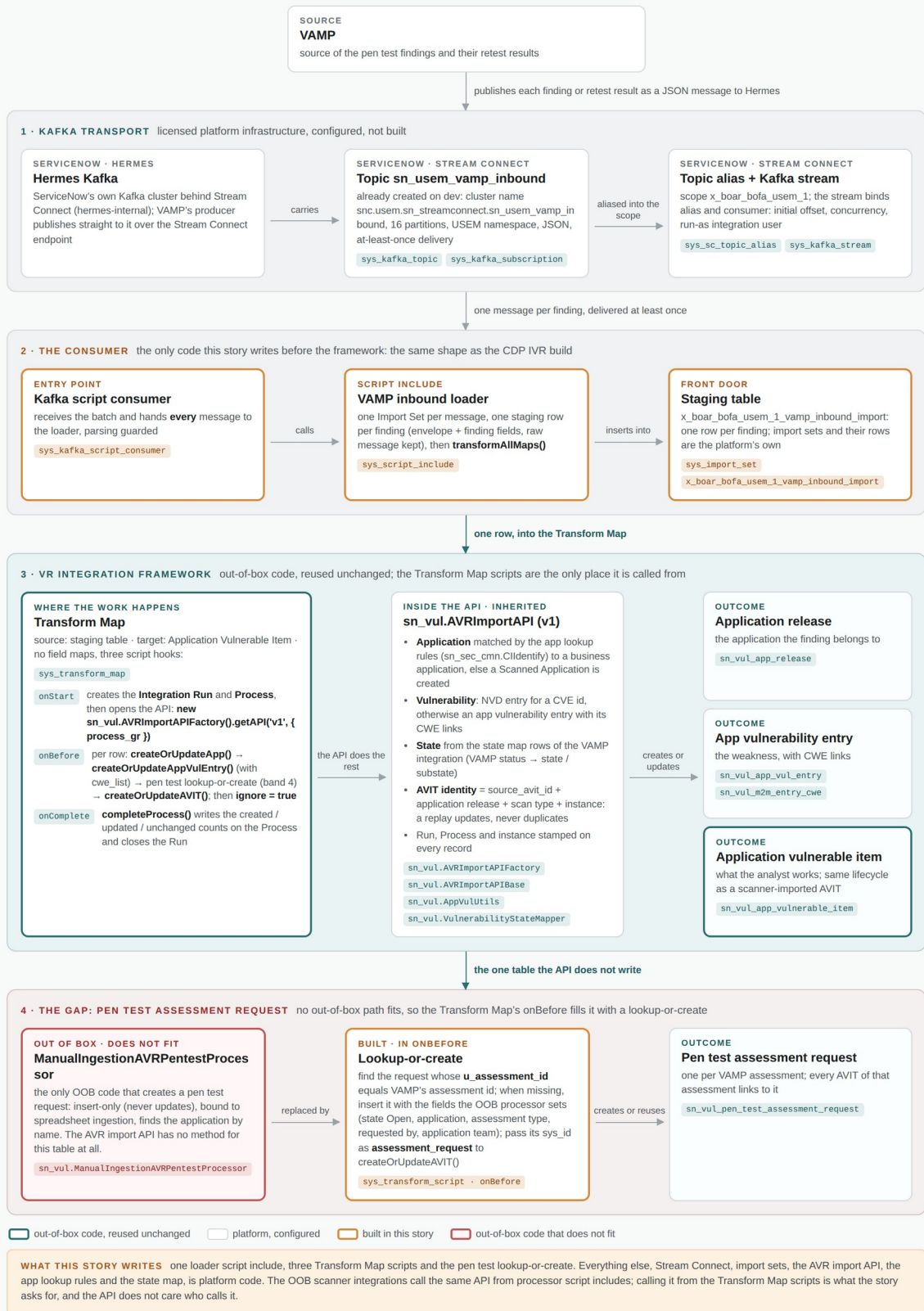


Figure 1. VAMP findings into Application Vulnerability Response. Bands 1 and 3 are platform code, configured or reused; band 2 and the right half of band 4 are what the story builds; the left card of band 4 is the out-of-box code that does not fit.